

COMPLETE WORKSHOP · LESSONS 1–8

OAuth 2.0, JWT/JOSE & FAPI 2.0

From the core mental model to high-security FAPI — one connected story.

Flows

Tokens

JWT / JOSE

Security controls

FAPI 2.0

Eight lessons, one mental model

1	OAuth Problem, Actors & Endpoints	Why OAuth exists; the four actors; tokens, scopes, consent
2	Authorization Code + PKCE	The main user flow; front vs back channel; PKCE
3	Client Credentials, Refresh & Device	Choose the right flow for the application shape
4	Token Validation & JWT Basics	Claims, decoding ≠ validation, the validation checklist
5	JWS, JWE, JWK / JWKS	Signing vs encryption; publishing and rotating keys
6	OAuth Security Controls	Deprecated flows; attacks mapped to mitigations
7	Advanced: PAR, JAR, JARM, DPoP, mTLS	Harden requests, responses, and token possession
8	FAPI 2.0	Stricter OAuth for high-value APIs

PART 01

OAuth Problem, Actors & Endpoints

OAuth lets a client get limited API access on a user's behalf — without ever receiving the password.

01

A framework, not a login or a token format

OAuth 2.0 IS

- An authorization framework (RFC 6749)
- A way to get limited, scoped access via tokens
- Answering: what may this client access?

OAuth 2.0 is NOT

- Password sharing
- A single endpoint or token format
- A complete login protocol (that's OpenID Connect)
- Automatically secure — implementation matters

Framework = the model · RFCs = the spec · Flows = ways to use it.

Password sharing is the wrong shape

Give away the password

- App can do everything you can
- No way to scope to one resource
- Revoking means changing the password
- App breach exposes the whole account

Give a scoped token

- Limited to exactly what's needed
- Password never leaves the trusted service
- Revoke just this app, anytime
- Token expires on its own

The client receives permission, not the user's password.

The four actors

Resource Owner

Owns the data — the user (e.g. you on GitHub)

Client

Wants access — the app (e.g. a deployment dashboard)

Authorization Server

Authenticates the user, gets consent, issues tokens

Resource Server

Hosts the API and validates access tokens

Identify them by asking: who owns the data, who wants access, who grants it, who serves the API?

Two endpoints, two channels

Endpoint	Job	Channel
/authorize	User logs in & approves access	Front-channel (browser) — more exposed
/token	Exchange a grant for an access token	Back-channel (server-to-server) — protected

Front-channel vs back-channel is the idea behind every later security control.

Also: the access token

Represents permission, not the user's password · scoped, expiring, revocable · checked by the resource server on every call.

OAuth vs OpenID Connect

	OAuth 2.0	OpenID Connect
Purpose	Authorization	Authentication
Question	What can this client access?	Who is the user?
Main token	Access token	ID token
Example	Connect GitHub repos / Drive files	“Log in with Google”

Wants to call an API → OAuth. Wants to know who you are → OpenID Connect.

PART 02

Authorization Code + PKCE

The browser carries only a short-lived code; tokens come from the back-channel.
PKCE protects the exchange.

02

Authorization Code, step by step

- 1 Client redirects the browser to /authorize
- 2 User logs in and approves at the authorization server
- 3 Server redirects back with a short-lived code + state
- 4 Client posts the code to /token (back-channel)
- 5 Client receives the access token (+ refresh token)
- 6 Client calls the API with the access token

Authorization request parameters

Parameter	Purpose
response_type=code	Ask for an authorization code
client_id	Identify the client
redirect_uri	Where the browser returns (must match registration)
scope	Permissions requested
state	Bind the callback to a request the client started (CSRF)
code_challenge (+ _method=S256)	PKCE challenge for the code exchange

A stolen code should not be enough

Without PKCE

- Attacker intercepts the authorization code
- Sends it to /token
- If the client is public, may get tokens

With PKCE

- Client first sends code_challenge (a hash)
- Later proves it with the code_verifier at /token
- Attacker has the code but not the verifier → fails

```
code_challenge = BASE64URL( SHA256(code_verifier) ) // S256, one-way
```

state vs redirect_uri vs PKCE

Check	Checked by	Protects
state	Client	Callbacks the client did not start (CSRF)
redirect_uri	Authorization server	Binds the code to the original request target
code_verifier / challenge	Token endpoint	Proves the redeemer knows the original secret

They solve different problems — a modern browser flow uses all three.

PART 03

Client Credentials, Refresh & Device

OAuth is not one flow — different trust situations need different flows.

03

Three more flows, three problems

Client Credentials

Machine-to-machine — no user, no browser, no consent. Token represents the service.

Refresh Token

Renew a short-lived access token without sending the user through the flow again.

Device Authorization

Limited-input devices (CLI, TV): user approves on a second device while the client polls.

Rotation makes reuse detectable

Step	What happens
Issue	Client gets access token AT1 + refresh token RT1
Refresh	AT1 expires; client sends RT1 to /token
Rotate	Server returns AT2 + RT2, marks RT1 used
Reuse seen	If RT1 appears again → treat as theft, revoke the family

An access token opens the door once; a refresh token can keep making new keys — store it well.

Choose the flow

Flow	User?	Redirect?	Main use	Today?
Auth Code + PKCE	Yes	Yes	Web, SPA, mobile with a user	Recommended
Client Credentials	No	No	Service-to-service APIs	Recommended
Refresh Token	Sometimes	No	Renew an access token	Recommended w/ controls
Device Authorization	Yes	Partial	CLI / TV / limited input	When appropriate
Implicit / Password	Yes	—	Legacy	Avoid

PART 04

Token Validation & JWT Basics

A JWT is only a format. Security comes from validation — decoding is not validation.

04

JWT: header . payload . signature

decoded payload

```
{
  "iss": "https://auth.example.com",
  "sub": "user_123",
  "aud": "https://api.example.com",
  "exp": 1760000000,
  "scope": "repo.read repo.write"
}
```

Claims that drive validation

- iss — do we trust this issuer?
- aud — is this token meant for this API?
- exp / nbf — is it valid right now?
- scope — enough permission for this action?

A signed JWT is only base64url-encoded — anyone holding it can read the payload.

What the resource server must check

Validation checklist

- Signature verifies with a trusted key
- alg is expected; kid is a trusted key
- iss trusted · aud is this API
- exp / nbf valid in time
- scope sufficient · correct token type

Reject for the right reason

- 401 Unauthorized — missing, expired, malformed, invalid token
- 403 Forbidden — valid token, but not enough scope
- Opaque (non-JWT) token? Call the introspection endpoint

PART 05

JWS, JWE, JWK / JWKS

JWS signs, JWE encrypts, JWK/JWKS publish the keys. Signed does not mean private.

05

Five pieces that fit together

Term	Purpose
JWT	Compact claims format (the container)
JWS	Signature — integrity / authenticity
JWE	Encryption — confidentiality
JWK	JSON representation of one key
JWKS	A published set of keys (selected by kid)

JWS proves the content was not modified. JWE hides the content.

Where the verifier gets the key

How verification works

- AS signs with its private key
- AS publishes the public key in JWKS
- Resource server fetches JWKS from a trusted jwks_uri
- Selects the key by kid, then verifies

Common alg / kid mistakes

- Accepting alg=none (unsigned tokens)
- Accepting any algorithm from the token header
- Fetching keys from a URL the token controls
- Removing an old key before old tokens expire

Allowed algorithms and key sources come from configuration — never from the token.

PART 06

OAuth Security Controls

Connect common attacks to the controls that stop them.

06

Avoid Implicit and Password grant

Implicit flow

- Returned tokens directly in the browser redirect
- Front-channel token exposure (history, logs, scripts)
- Replaced by Auth Code + PKCE

Password credentials

- Client collects the user's real password
- Breaks the core OAuth idea
- Blocks MFA; a breached client exposes credentials

Use Auth Code + PKCE for users, Client Credentials for services.

Attacks mapped to mitigations

Attack / mistake	Mitigation
Missing state	Generate, store, and verify state
Weak redirect URI matching	Exact, pre-registered redirect URIs
Authorization code interception	PKCE + short-lived single-use codes
Long-lived / stolen access token	Short token lifetime
Refresh token theft	Rotation + reuse detection
Bearer token replay	Sender-constrained tokens (DPoP / mTLS)

PART 07

Advanced: PAR, JAR, JARM, DPoP, mTLS

Harden the request, the response, and proof of token possession.

07

PAR, JAR, JARM

Control	What it does	Protects
PAR	Push request details to a back-channel endpoint	Request exposure in the browser
JAR	Sign the authorization request (a JWT)	Request-parameter integrity
JARM	Sign the authorization response (a JWT)	Response integrity, mix-up

PAR pushes the request back-channel · **JAR** signs the request · **JARM** signs the response.

DPoP vs mTLS

DPoP

- Application-layer signed proof per request
- Token bound to a public key
- Fits public clients & APIs

mTLS

- TLS-layer client certificate
- Certificate-bound access tokens
- Fits confidential / high-security clients

Both sender-constrain the token: a stolen bearer token alone is no longer enough.

PART 08

FAPI 2.0

A high-security profile — stricter OAuth for high-value APIs, not a replacement protocol.

08

Stricter OAuth, combined

FAPI 2.0 combines

- Strict OAuth configuration
- PAR + sender-constrained tokens
- Strong client authentication
- Strict token validation
- Optional message signing (non-repudiation)

Where it's used

- Open banking & payments
- Healthcare & sensitive identity APIs
- Regulated / high-impact data APIs

Normal OAuth gives options; FAPI chooses the strict ones for high-value APIs.

FAPI controls mapped to risk

Risk	FAPI-oriented control
Authorization request tampering	PAR + signed request objects (JAR)
Bearer token replay	Sender-constrained tokens (DPoP / mTLS)
Weak client authentication	Private-key or certificate-based auth
Token accepted by the wrong API	Strict audience validation
Payment / consent dispute	Message signing + audit evidence

YOU CAN TEACH THIS WHEN...

Ready to teach

- ✓ Draw Auth Code + PKCE and Client Credentials from memory
- ✓ Explain code vs access vs refresh vs ID token
- ✓ List the JWT validation checks and why decoding isn't validation
- ✓ Connect attacks to mitigations: PKCE, state, redirect matching, DPoP/mTLS
- ✓ Explain FAPI as strict OAuth for high-value APIs